LAB - DAY 9

Higher National Diploma in Network Engineering, Year 2
BSc (Hons) Ethical Hacking & Network Security, Year 2

Taxila's risk register and continuity plan



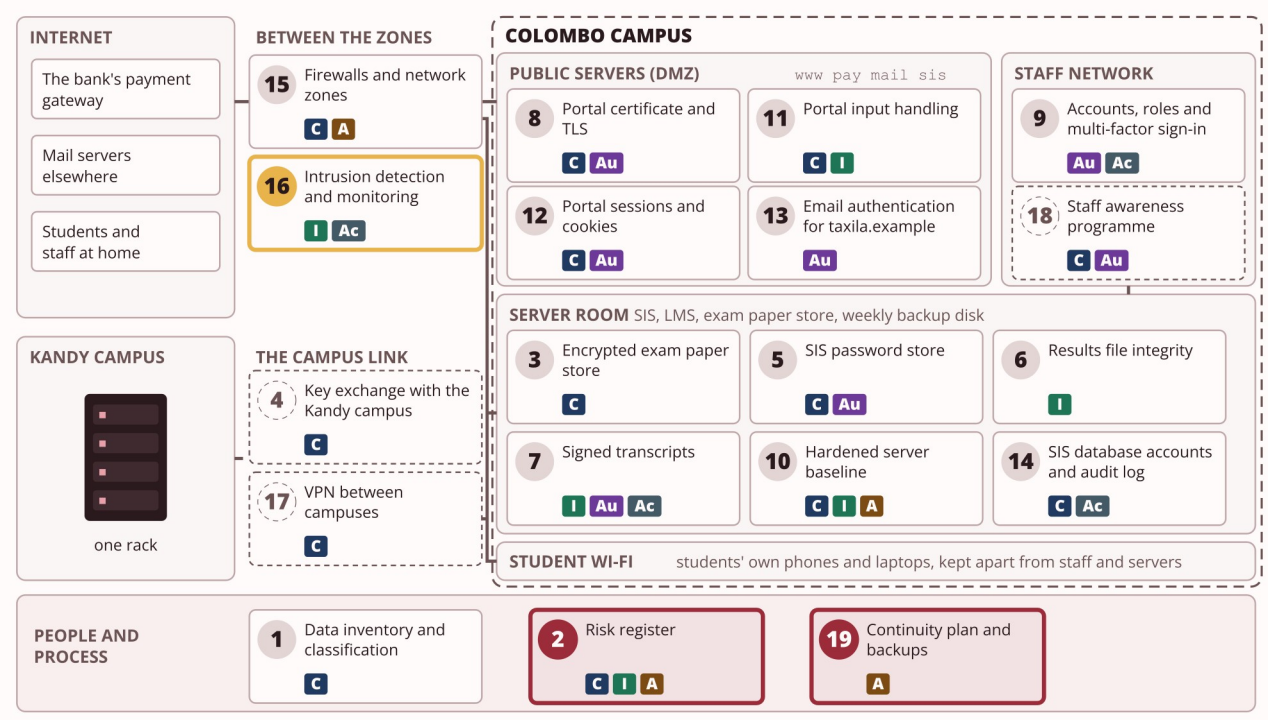
Adds to the register: **2** **19**

Floor tier: every step

Full tier: not needed

Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management

The security register



TODAY

2 Risk register

19 Continuity plan and backups

KEY

- Added today
- Added earlier
- Demonstrated
- Concept only

IT

HEAD OF IT

I cannot fix everything at once. Tell me what we do about each risk, who owns it, and how we bring the SIS back.

The Head of IT, at the start of the lab.

Two common mistakes

Are the RTO and the RPO the same number?	No: one is downtime, the other is data lost.
Is a register written once and filed away?	No: it is reviewed as threats and systems change.

Today you change rows you wrote on Day 1, because you now know more.

SEGMENT 1 - 50 MIN

Complete Taxila's risk register

Floor tier only

Bring the register up to date

1 Copy your ten rows into `risk-register-day-9.csv`.

Expected: Ten rows; the five new columns empty.

Floor path: The whole lab is floor tier.

2 Keep at least ten rows; at least three from Days 5 to 8.

Expected: Every row names a real Taxila asset and one property.

```
Treatment   Action                          Owner       Residual
Mitigate    encrypt the exam paper store    Registrar   1 x 5 = 5
```

Your Day 1 treatment idea goes in the Action column.

Treat, own and rate what remains

3 Write mitigate, avoid, transfer or accept, and the action.

Expected: Most rows mitigate; at least one transfer or accept.

4 Name an owner: the Registrar, the Head of IT or the Data Protection Officer.

Expected: Every accept row has an owner and a reason.

5 Rate the residual likelihood and impact; sort by residual score.

Expected: Mitigate and avoid rows fall; accept rows keep their score.

A risk nobody wrote down was not accepted: it was missed.

SEGMENT 2 - 45 MIN

A business impact analysis for the fee page and the Student Information System

Floor tier only

Read the facts

6 Read `bia-facts.txt` and mark what changes the harm.

Expected: 600 payments an hour on a deadline evening; the weekly disk.

```
Fee page    ordinary evening     about 20 payments an hour
            deadline evening     about 600 payments an hour
SIS         marking weeks        about 1,200 grades a day
Backups     one disk a week, in the server room, never restored
```

The figures belong to the teaching scenario only.

Rate the harm, then the order

7 Rate each service after one hour, one day, one week.

Expected: The fee page rises steeply; the SIS is critical to everything.

8 Set the recovery priority, with a reason.

Expected: The SIS first: the fee page depends on it.

Service	1 hour	1 day	1 week	Priority
Fee page	4 to 5	5	5	2
SIS	3 to 4	4	5	1

Restoring the fee page alone lets nobody pay.

SEGMENT 3 - 35 MIN

A continuity plan with recovery objectives and the three-two-one rule

Floor tier only

Two objectives for each service

9 Write an RTO and an RPO for each service, argued from the facts.

Expected: Fee page: about one hour each. SIS: a few hours; about one hour.

```
Fee page    RTO about 1 hour      RPO about 1 hour
            (deadline evening)    (the bank's statement rebuilds it)
SIS         RTO a few hours       RPO about 1 hour
            (within a day)        (1,200 grades a day)
```

Every number needs a reason from bia-facts.txt.

Backups that follow the recovery point

10 Write three copies, two kinds of storage, one off-site.

Expected: A copy at least every hour; one off-site; a tested restore.

11 Write the recovery steps, in order.

Expected: Check the data before users return.

```
Copy 1   the live database in the server room
Copy 2   every hour, to a second disk
Copy 3   every day, to the rack in Kandy
Test     restore to the spare server, and check grades
```

The backup frequency follows from the recovery point.

SEGMENT 4 - 20 MIN

Check it and hand to your group

Floor tier only

Check it and hand it on

12 Swap files with a partner and use the checklist.

Expected: Every item ticked or fixed.

13 Hand your register, worksheet and plan to your group.

Expected: One register and one plan for Day 10.

```
Every row: property, treatment, action, owner
Every accept row: a reason
Every RTO and RPO: argued from a fact
Every backup: at least as often as its RPO
One copy off-site; the restore tested
```

Prove it, then break it

PROVE IT

- Every register row names its **property** and a treatment
- The fee page's RTO and RPO argued from deadline night
- Each number traced to a line in the facts

× BREAK IT

- Set the SIS backup to **weekly** against an RPO of one hour
- A marking week lost: about **6,000** grades to re-enter
- Fix: a backup at least every hour

Reset, and the rules

RESET

- Nothing to reset; this lab changes no system
- Delete the broken copy of your plan
- Keep your three files for your group

RULES OF ENGAGEMENT

- No tool in this lab can affect anyone else's system
- Only your own files and the provided worksheets
- No system of any kind is changed

Before the next day

READ	**Security in Computing, sections 10.2 to 10.4** Continuity planning, incidents and risk analysis
PRACTICE	**Practice question 9** The ride-hailing app
TASK	**Your group's register and plan** Finish them for the Day 10 exercise

Questions & Discussion

Next: Day 10, the group exercise, synthesis and exam preparation.



Disclaimer & Copyright

The information in this presentation is for general teaching purposes only. It is not comprehensive and is not professional advice; any reliance you place on it is at your own risk. I aim to keep it accurate, but I make no representations or warranties of any kind about its completeness, accuracy, reliability or suitability.

Security tools, standards and laws change. Versions, editions and commencement dates in this presentation were checked at the time of writing; check the current documentation before relying on them.

This presentation may refer to third-party websites or content. I do not endorse their views or information, and I am not responsible for their content.

Taxila College is fictional. Its campuses, people, systems and incidents were invented for teaching. Product and tool names, for example Kali Linux, VirtualBox, CyberChef and Wireshark, belong to their owners; this material is not affiliated with or endorsed by any of them.

Practise only on your own virtual machine, the module's provided files and application, and the portal's demos. Testing a system you do not own, without written permission, is an offence under Sri Lanka's Computer Crime Act, No. 24 of 2007.

© Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content under CC BY-NC-SA 4.0; code and demonstrations under MIT; Open Sans under the SIL Open Font Licence.

Revision 053a4e5